

1. 무선 네트워크의 암호화 키(WEP, WPA 등)를 크랙(crack)하는 데 가장 널리 사용되는 도구는 무엇인가?

- ① Cain & Abel
- ② aircrack-ng
- ③ John the Ripper
- ④ Ettercap

정답: ② aircrack-ng

설명: → AI 추가 제시

- cowpatty (WPA-PSK 크랙)
- reaver (WPS 취약점 이용)
- fern wifi cracker (GUI 기반)

2. FTP 서비스에서 root 계정의 접속을 제한하기 위한 설정으로 올바른 것은?

- ① /etc/ftpusers / root
- ② /etc/ftpusers / bin
- ③ /etc/ftpuser / root
- ④ /etc/ftpuser / admin

3. 다음 중 악성코드의 동적 분석 도구로 가장 적합한 것은 무엇인가?

- ① OllyDbg
- ② IDA Pro
- ③ Autoruns
- ④ PEiD

정답: ③ Autoruns

설명: Autoruns는 윈도우 시스템에서 자동 실행되는 프로그램(시작프로그램, 서비스 등)을 분석하여 악성코드의 동작을 동적으로 추적할 수 있는 도구입니다. (정적 분석 도구와 혼동하지 않도록 주의)

4. 다음 중 ARP 스누핑과 DNS 스누핑의 공통점으로 가장 적절한 것은?

- ① 스니핑 공격에 활용된다.
- ② 패킷을 암호화한다.
- ③ 인증 서버를 우회한다.
- ④ 방화벽을 우회한다.

정답: ① 스니핑 공격에 활용된다. 경유지를 이용한다 IP 주소 변조를 포함한다 등이 나올 수 있으며, 스니핑(도청) 공격 활용 또는 IP 주소 변조가 정답입니다.

5. 다음 중 DNS 터널링에 대한 설명으로 옳은 것은?

- ① DNS 터널링 사용 시 모니터링이 불가하다.
- ② DNS 터널링은 정상적인 DNS 조회만을 수행한다.
- ③ 공격자가 우회를 위해서 자주 사용한다.
- ④ DNS 터널링은 트래픽을 암호화하지 않는다.

정답: ③ 공격자가 우회를 위해서 자주 사용한다.

설명: DNS 터널링은 방화벽이나 보안 장비를 우회하기 위해 공격자가 자주 사용하는 기법입니다. 따라서 "공격자가 우회를 위해서 자주 사용"이 정답입니다.

6. 다음 중 Kerberos(커버로스)에 대한 설명으로 틀린 것은?

- ① Kerberos는 대칭키 암호 방식을 사용한다.
- ② Kerberos는 인증을 위해 티켓(ticket)을 사용한다.
- ③ Kerberos는 공개키 암호 방식을 사용한다.
- ④ Kerberos는 네트워크 상에서 사용자 인증을 제공한다.

정답: ③ Kerberos는 공개키 암호 방식을 사용한다.

설명: Kerberos는 대칭키 암호 방식만 사용하며, 공개키 암호 방식은 사용하지 않습니다. 따라서 "Kerberos는 공개키 암호 방식을 사용한다"가 틀린 설명입니다.

7. X Client 원격 접속 시 루트 사용자 제한을 위한 명령어 및 설정 파일로 옳은 것은?

- ① xhost - \$XAUTHORITY
- ② xhost - /root/.xauthority
- ③ xauth - \$XAUTHORITY
- ④ xauth - /root/.xauthority

정답: ④ xauth - /root/.xauthority

설명: xauth 명령어와 /root/.xauthority 파일을 이용하여 X Client의 루트 사용자 원격 접속을 제한할 수 있습니다.

8. PDoS(Permanent Denial of Service) 공격에 대한 설명으로 옳은 것은?

- ① 시스템의 하드웨어나 펌웨어를 손상시켜 영구적으로 서비스 거부 상태를 유발한다.
- ② 네트워크 대역폭을 소진시켜 일시적으로 서비스 거부 상태를 만든다.
- ③ 정상적인 사용자로 위장하여 서비스에 지속적으로 접속한다.
- ④ 서버의 응답 속도를 느리게 하여 서비스 거부 상태를 만든다.

정답: ① 시스템의 하드웨어나 펌웨어를 손상시켜 영구적으로 서비스 거부 상태를 유발한다.

설명: PDOS는 하드웨어나 펌웨어를 손상시켜 복구가 불가능하거나 매우 어려운 영구적인 서비스 거부 상태를 만드는 공격입니다. (DDoS처럼 일시적이 아닌, 영구적 피해가 특징입니다.)

9. 다음 중 CentOS 7 이상에서 계정 잠금 및 암호 품질 관리를 위해 사용하는 PAM 모듈로 옳은 것은?

- ① pam_tally
- ② pam_tally2
- ③ pam_pwquality
- ④ pam_cracklib

정답: ② pam_tally2, ③ pam_pwquality

설명: pam_tally2 : 로그인 실패 횟수 제한(계정 잠금) pam_pwquality : 암호 복잡성(품질) 정책 적용 (CentOS 7 이상에서는 pam_tally 대신 pam_tally2, pam_cracklib 대신 pam_pwquality 사용)

10. nmap 명령어 중 운영체제(OS) 정보를 식별하기 위해 사용하는 옵션은 무엇인가?

- ① -sS
- ② -O
- ③ -sU
- ④ -A

정답: ② -O

설명: nmap -O 옵션은 운영체제(OS) 탐지(Operating System Detection)를 위한 명령어입니다. (참고: -A 옵션은 OS 탐지와 함께 서비스 버전, traceroute 등 추가 정보도 함께 제공합니다.)

11. 다음 중 NetBIOS에 대한 설명으로 옳지 않은 것은?

- ① NetBIOS는 네트워크 기본 입출력 시스템(Network Basic Input/Output System)이다.
- ② NetBIOS는 OSI 7계층의 응용 계층에서 동작한다.
- ③ NetBIOS는 컴퓨터 이름을 IP 주소로 변환하는 역할을 한다.
- ④ NetBIOS는 TCP/UDP 포트 137, 138, 139를 사용한다.

정답: ③ NetBIOS는 컴퓨터 이름을 IP 주소로 변환하는 역할을 한다.

설명: NetBIOS는 컴퓨터 이름을 IP 주소로 변환하는 것이 아니라, 컴퓨터 이름 기반의 통신을 지원합니다. 이름을 IP로 변환하는 역할은 NetBIOS over TCP/IP(NBT)에서 이루어지며, 실제 변환은 WINS(Windows Internet Name Service)나 DNS가 담당합니다.

12. 다음 중 DEP(Data Execution Prevention)/NX bit를 이용하여 방지할 수 있는 공격은 무엇인가?

- ① SQL 인젝션
- ② 버퍼 오버플로우
- ③ 세션 하이재킹
- ④ 피싱

정답: ② 버퍼 오버플로우

설명: DEP/NX bit는 데이터 영역의 코드 실행을 차단하여 버퍼 오버플로우(Buffer Overflow)와 같은 메모리 기반 공격을 방지합니다. (Heap Spray, 스택 기반 셸코드 실행 등도 방지 가능)

13. 다음 중 dig -x 8.8.8.8 명령어의 기능으로 옳은 것은?

- ① 도메인 이름을 IP 주소로 변환한다.
- ② IP 주소에 대한 역방향(DNS Reverse) 조회를 수행한다.
- ③ 네트워크 인터페이스 정보를 확인한다.
- ④ DNS 서버의 캐시를 삭제한다.

정답: ② IP 주소에 대한 역방향(DNS Reverse) 조회를 수행한다.

설명: dig -x 8.8.8.8 명령어는 IP 주소(8.8.8.8)에 대한 역방향 DNS 조회(Reverse Lookup)를 수행하여 해당 IP에 매핑된 도메인 이름을 확인합니다.

14. 다음 중 윈도우 로그인 과정에서 필요하지 않은 것은 무엇인가?

- ① LSA
- ② SAM
- ③ SRM
- ④ SID

정답: ④ SID

설명: LSA(Local Security Authority): 보안 정책 관리 SAM(Security Account Manager): 계정 정보 저장 SRM(Security Reference Monitor): 접근 제어 SID(Security Identifier): 계정의 고유 식별자(로그인 과정에서 직접적으로 사용되지는 않음) 따라서, SID가 정답입니다.

15. 다음 중 윈도우에서 SID(Security Identifier)에 권한을 할당하는 역할을 하는 것은 무엇인가?

- ① LSA
- ② SAM
- ③ SRM
- ④ ACL

정답: ④ ACL

설명: SID(Security Identifier)는 계정의 고유 식별자입니다. ACL(Access Control List)은 SID에 권한(Access Permission)을 할당하는 역할을 합니다. LSA, SAM, SRM은 각각 보안 정책, 계정 정보, 접근 제어와 관련되어 있지만, 실제로 SID에 권한을 부여하는 것은 ACL입니다.

16. 다음 중 디지털 핑거프린팅(Digital Fingerprinting)에 대한 설명으로 틀린 것은?

- ① 구매자마다 일부 정보가 다를 수 있다.
- ② 생성자와 구매자 정보가 포함될 수 있다.
- ③ 불법 복제 추적에 활용된다.
- ④ 암호화된 데이터는 핑거프린팅이 불가능하다.

정답: ④ 암호화된 데이터는 핑거프린팅이 불가능하다.

설명: 디지털 핑거프린팅은 구매자마다 일부 정보가 다르게 삽입되어 불법 복제 추적에 활용되며, 생성자·구매자 정보가 포함될 수 있습니다. 암호화 여부와 무관하게 핑거프린팅 정보는 데이터에 삽입될 수 있으므로, "암호화된 데이터는 핑거프린팅이 불가능하다"는 설명이 틀린 것입니다.

17. 다음 중 PGP(Public Key 기반 암호화)에서 메시지 압축과 암호화의 올바른 순서는 무엇인가?

- ① 메시지 압축 → 대칭키 암호화 → 공개키 암호화
- ② 메시지 압축 → 공개키 암호화 → 대칭키 암호화
- ③ 대칭키 암호화 → 메시지 압축 → 공개키 암호화
- ④ 공개키 암호화 → 메시지 압축 → 대칭키 암호화

정답: ① 메시지 압축 → 대칭키 암호화 → 공개키 암호화

설명: PGP에서는 메시지를 먼저 압축 압축된 메시지를 대칭키로 암호화 대칭키(세션키)를 수신자의 공개키로 암호화 이 순서로 처리합니다.

18. 다음 중 IPSEC의 AH(Authentication Header)의 역할로 옳은 것은?

- ① 데이터의 무결성과 인증을 제공한다.
- ② 데이터의 기밀성을 제공한다.
- ③ 데이터의 암호화만 제공한다.
- ④ 데이터의 압축을 제공한다.

정답: ① 데이터의 무결성과 인증을 제공한다.

설명:

****AH(Authentication Header)****는 IPSEC에서 데이터의 무결성과 인증을 제공합니다. ****암호화(기밀성)****는 ESP(Encapsulating Security Payload)에서 담당합니다. AH는 데이터의 변조 여부와 송신자 인증을 보장하지만, 데이터 자체를 암호화하지는 않습니다.

19. 다음 중 BOF(Buffer Overflow) 방지 기법에 대한 설명으로 옳지 않은 것은?

- ① ASLR은 메모리 주소를 무작위로 할당하여 공격을 어렵게 한다.
- ② Stack Canary는 스택 오버플로우를 탐지하여 공격을 방지한다.
- ③ NX bit는 데이터 영역의 코드 실행을 차단한다.
- ④ Stack Shield는 네트워크 트래픽을 암호화하여 BOF를 방지한다.

정답: ④ Stack Shield는 네트워크 트래픽을 암호화하여 BOF를 방지한다.

설명: Stack Shield는 함수 리턴 주소를 보호하여 스택 기반 버퍼 오버플로우를 방지하는 기법이지, 네트워크 트래픽 암호화와는 관련이 없습니다. 나머지 보기들은 모두 BOF 방지와 직접적으로 관련된 설명입니다.

20. 다음 중 ls -al 명령어 출력 사진에서 파일 권한 정보 끝에 나타나는 "+" 기호의 의미로 올바른 것은?

- ① 파일이 숨김 파일임을 나타낸다.
- ② 파일에 하드 링크가 있음을 나타낸다.
- ③ ACL(Access Control List)가 설정되어 있음을 나타낸다.
- ④ 파일이 읽기 전용임을 나타낸다.

정답: ③ ACL(Access Control List)가 설정되어 있음을 나타낸다.

설명: ls -al 명령어에서 파일 권한 끝에 "+"가 표시되면, 해당 파일이나 디렉터리에 추가적인 접근 제어 목록(ACL)이 설정되어 있음을 의미합니다.

21. 다음 중 ModSecurity에 대한 설명으로 옳지 않은 것은?

- ① Apache, Nginx, IIS 등 다양한 웹 서버에서 사용할 수 있다.
- ② 웹 요청을 실시간으로 검사하여 공격을 차단할 수 있다.

- ③ ModSecurity는 방화벽 장비로 동작한다.
- ④ SQL Injection, XSS와 같은 웹 공격 탐지 및 차단이 가능하다.

정답: ③ ModSecurity는 방화벽 장비로 동작한다.

설명: ModSecurity는 소프트웨어 기반의 웹 애플리케이션 방화벽(WAF)으로, 웹 서버에 모듈 형태로 설치되어 동작합니다. 따라서 "방화벽 장비로 동작한다"는 설명은 옳지 않습니다. 나머지 보기들은 모두 ModSecurity의 특징에 해당합니다.

22. 사용자/기기/서비스에 대해 항상 인증하고 검증, 내부망도 신뢰하지 않으며, 마이크로 세분화 및 지속적 모니터링 기반의 최신 보안 모델은 무엇인가?

- ① 방화벽
- ② 제로 트러스트(Zero Trust)
- ③ VPN
- ④ IDS

정답: ② 제로 트러스트(Zero Trust)

설명: 제로 트러스트(Zero Trust)는 "아무도 신뢰하지 않는다(Trust No One)"는 원칙에 따라, 내부망도 신뢰하지 않고 모든 접근에 대해 지속적으로 인증·검증하는 최신 보안 모델입니다.

23. 스푸핑 명령어 중 읽기 권한만 허용하려면 어떤 옵션을 사용하는가?

- ① msof
- ② ro
- ③ pam
- ④ (기타 보기)

정답: ② ro

설명: ro는 read-only(읽기 전용)의 약어로, 읽기 권한만 허용할 때 사용하는 옵션입니다. NFS(Network File System) 등에서 마운트 옵션으로 ro를 사용하면 읽기 권한만 부여됩니다.

24. 보기 설명에 알맞은 DNS 응답 메시지 유형으로 올바른 것은?

- ① authorized-answer
- ② cache-answer
- ③ non-authorized-answer
- ④ non-cache-answer

정답: ② cache-answer

설명: DNS 서버가 자신이 직접 권한을 가진 영역(zone)이 아닌, 다른 서버에서 받아온 정보를 응답할 때 cache-answer(캐시 응답) 유형을 사용합니다. 즉, 권한이 없는 서버가 캐시에 저장된 정보를 응답할 때 "cache-answer"가 정답입니다. (권한이 있는 서버가 직접 응답하면 authorized-answer, 권한이 없는 서버가 캐시에서 응답하면 cache-answer)

25. 다음 중 PKI(Public Key Infrastructure)에 대한 설명으로 틀린 것은?

- ① 인증기관(CA)은 공개키 인증서의 발급과 폐지를 담당한다.
- ② 검증기관(VA)은 전자서명의 유효성을 검증하는 역할을 한다.
- ③ 등록기관(RA)은 이용자의 신원을 확인하고 인증서를 직접 발급한다.
- ④ 인증서 폐지 목록(CRL)은 폐기된 인증서 정보를 포함한다.

정답: ③ 등록기관(RA)은 이용자의 신원을 확인하고 인증서를 직접 발급한다.

설명: 등록기관(RA, Registration Authority)은 이용자의 신원을 확인하지만, 인증서를 직접 발급하지 않고 인증기관(CA)에 발급을 요청합니다. 인증서의 실제 발급과 폐지는 인증기관(CA)이 담당합니다. 따라서 ③번이 틀린 설명입니다.

26. 사용자 A가 메시지를 암호화하고, B의 공개키를 사용하는 구조는?

- ① 전자봉투
- ② 전자서명
- ③ 은닉서명
- ④ 인증서

정답: ① 전자봉투

설명: 전자봉투(Envelope)는 수신자(B)의 공개키로 메시지를 암호화하여, 오직 B만이 자신의 개인키로 복호화할 수 있도록 하는 구조입니다. 전자서명은 송신자의 개인키로 서명하는 방식입니다.

27. 전자서명에서 전체 메시지를 암호화하지 않고, 해시 함수를 사용하여 생성하는 것은 무엇인가?

- ① 전자봉투
- ② 메시지 다이제스트
- ③ 대칭키
- ④ 인증서

정답: ② 메시지 다이제스트

설명: 전자서명에서는 전체 메시지를 암호화하지 않고, 해시 함수를 이용해 메시지 다이제스트(Message Digest)를 생성한 후, 이 다이제스트에 송신자의 개인키로 서명합니다. 이렇게 하면 데이터의 무결성과 송신자 인증을 동시에 보장할 수 있습니다.

28. 전자서명 시 http 기반 보안 프로토콜은 무엇인가?

- ① SSL
- ② SSTP
- ③ PPTP
- ④ L2TP

정답: ① SSL

설명: SSL(Secure Sockets Layer)은 HTTP와 결합하여 HTTPS로 사용되며, 전자서명 등 웹 기반 보안 통신에 널리 사용되는 프로토콜입니다. SSTP, PPTP, L2TP는 주로 VPN 관련 프로토콜입니다.

29. 일방향 해시함수 공격 방법 중 옳은 것은?

- ① 일치블록
- ② 무차별 대입(Brute Force)
- ③ 차분(차분공격, Differential Attack)
- ④ 생일 공격(Birthday Attack)

정답: ④ 생일 공격(Birthday Attack)

설명: 일방향 해시함수 공격 방법에는 무차별 대입 공격(Brute Force Attack), 생일 공격(Birthday Attack), 충돌 공격(Collision Attack) 등이 있습니다. 특히 생일 공격은 해시 함수의 충돌 가능성을 이용한 대표적인 공격 방법입니다. (차분공격은 주로 대칭키 블록 암호에 사용됩니다.)

30. 스마트 월패드 보안 방안으로 틀린 것은?

- ① 유추 가능한 id/pw 구현 방지
- ② sha128 알고리즘 이용해 암호 저장
- ③ 출고 당시의 비밀번호는 대부분 공통값으로 변경 필요
- ④ 주기적인 업데이트 필요

정답: ② sha128 알고리즘 이용해 암호 저장

설명: SHA-128은 존재하지 않는 해시 알고리즘이며, 안전하지 않은 암호화 방식입니다. 실제로는 SHA-256, SHA-512 등 검증된 해시 알고리즘을 사용해야 합니다. 나머지 보기들은 모두 올바른 보안 방안입니다.

31. 다음 중 SSL 3.0을 강제화하여 발생하는 보안 취약점(공격)으로 옳은 것은?

- ① POODLE 공격
- ② Heartbleed
- ③ Slowloris
- ④ Shellshock

정답: ① POODLE 공격

설명: POODLE(패딩 오라클 온 다운그레이드드 레거시 인크립션, Padding Oracle On Downgraded Legacy Encryption) 공격은 SSL 3.0 프로토콜의 취약점을 이용한 공격입니다. SSL 3.0을 강제화하거나 다운그레이드될 경우, 이 취약점에 노출될 수 있습니다. 따라서 SSL 3.0 강제화와 관련된 대표적인 보안 이슈는 POODLE 공격입니다.

32. DNSSEC를 도입하는 주요 목적 중 파밍(Pharming) 공격을 방지하기 위한 장비 또는 시스템은 무엇인가?

- ① ESM
- ② DNSSEC
- ③ 방화벽
- ④ IDS

정답: ② DNSSEC

설명: DNSSEC(Domain Name System Security Extensions)은 DNS 응답에 전자서명을 추가하여, DNS 레코드의 위변조를 방지하고 파밍(Pharming)과 같은 공격을 막기 위한 보안 기술입니다. 따라서 파밍 공격 방지와 관련된 정답은 DNSSEC입니다.

만약 "해당 장비는 무엇인가?"라는 식으로 물으면, 정답: ESM(Enterprise Security Management) 이 될 수 있으나, 파밍 방지의 핵심 기술은 DNSSEC입니다.

문제의 맥락에 따라 답이 달라질 수 있으니, 파밍 방지 기술로는 DNSSEC이 가장 대표적입니다.

33. 다음 중 HMAC(Hash-based Message Authentication Code)의 특징으로 옳지 않은 것은?

- ① 해시 함수와 비밀키를 함께 사용한다.
- ② 메시지의 무결성과 인증을 제공한다.
- ③ 대칭키 암호화 알고리즘만을 사용한다.
- ④ MD5, SHA-1 등 다양한 해시 함수를 사용할 수 있다.

정답: ③ 대칭키 암호화 알고리즘만을 사용한다.

설명: HMAC은 해시 함수와 비밀키를 함께 사용하여 메시지 인증 코드를 생성합니다. 메시지의 무결성과 인증을 제공합니다. MD5, SHA-1, SHA-256 등 다양한 해시 함수를 사용할 수 있습니다. HMAC은 대칭키 암호화 알고리즘이 아니라, 해시 함수 기반의 인증 코드입니다. 따라서 ③번이 틀린 설명입니다.

34. 로그를 정기적으로 보려고 하는데 볼 필요 없는 로그는?

- ① utmp
- ② wtmp
- ③ btmp
- ④ xferlog

정답: ① utmp

설명: utmp: 현재 로그인한 사용자 정보를 저장(실시간 정보, 정기적 분석에는 불필요) wtmp: 로그인/로그아웃 이력(정기적 분석에 유용) btmp: 로그인 실패 이력(정기적 분석에 유용) xferlog: FTP 전송 이력(정기적 분석에 유용) 따라서, 정기적으로 분석할 필요가 없는 로그는 utmp입니다.

35. 다음 중 OSI 7계층의 응용계층(7계층)에 속하지만, 성격이 다른 프로토콜은 무엇인가?

- ① S/MIME
- ② PGP
- ③ PEM
- ④ SSH

정답: ④ SSH

설명: S/MIME, PGP, PEM은 모두 이메일 보안 프로토콜입니다. SSH는 원격 접속(터미널 접속) 및 파일 전송 등에 사용되는 보안 프로토콜로, 이메일 보안과는 성격이 다릅니다. 따라서 성격이 다른 프로토콜은 SSH입니다. 유사하게 SSL, TLS 등이 보기로 나올 수 있으나, 이메일 보안 프로토콜과 구분되는 SSH가 대표적인 정답입니다.

36. 다음 중 스피어 피싱(Spear Phishing) 공격에 대한 설명으로 옳은 것은?

- ① 불특정 다수를 대상으로 무작위로 악성 이메일을 발송하는 공격
- ② 특정 개인이나 조직을 표적으로 맞춤형 악성 이메일을 발송하는 공격
- ③ 네트워크 트래픽을 가로채는 공격
- ④ 시스템의 취약점을 자동으로 탐지하는 공격

정답: ② 특정 개인이나 조직을 표적으로 맞춤형 악성 이메일을 발송하는 공격

설명: 스피어 피싱은 한 사람이 자주 사용하는 곳(조직, 개인 등)에 잠복하여, 맞춤형 악성코드나 피싱 이메일을 보내는 표적형 공격입니다. 불특정 다수를 노리는 일반 피싱과 달리, 특정 대상을 정밀하게 노린다는 점이 특징입니다.

37. 소규모 환경에서 주로 사용하는 DNS 서버(또는 dhns 서버)의 이름은 무엇인가?

- ① 권한 네임서버(Authoritative Name Server)
- ② 캐싱 전용 네임서버(Caching-only Name Server)
- ③ 루트 네임서버(Root Name Server)
- ④ 프라이머리 네임서버(Primary Name Server)

정답:

② 캐싱 전용 네임서버(Caching-only Name Server)

설명:

소규모 환경에서는 **캐싱 전용 네임서버**(caching-only name server)를 주로 사용합니다.

이 서버는 자체적으로 권한(zone) 정보를 가지지 않고, 다른 DNS 서버에서 얻은 정보를 캐시에 저장하여 응답합니다.

dhns(Distributed Host Name Server)도 소규모 환경에서 사용되는 분산형 네임서버로 언급될 수 있지만, 시험에서는 **캐싱 전용 네임서버**가 대표적인 정답입니다.

38. 다음 중 우리나라에서 개발된 블록 암호 알고리즘으로, 128비트 블록 크기와 128/192/256비트 키 길이를 지원하며, 전자정부, 금융 등에서 표준으로 사용되는 것은 무엇인가?

- ① AES
- ② DES
- ③ SEED
- ④ RC4

정답:

③ SEED

설명:

SEED는 한국인터넷진흥원(KISA)에서 개발한 128비트 블록 암호화 알고리즘으로, 국내 전자정부, 금융권 등에서 표준으로 사용됩니다.

128/192/256비트 키 길이를 지원하며, 안전성과 효율성이 검증된 우리나라 표준 암호입니다.

38. 다음은 YARA 룰에 대한 설명이다. 보기 중 틀린 것을 고르시오.

- YARA 룰 예시:

```
rule ExampleRule {
  strings:
    $a = "malware"
    $b = "virus"
    $c = "trojan"
  condition:
    $a or $b or $c
}
```

- ① 세 문자열 중 하나라도 포함되면 탐지된다.
- ② 세 문자열이 모두 포함되어야 탐지된다.
- ③ condition 절에 따라 탐지 조건이 결정된다.
- ④ strings 절에는 탐지할 문자열을 정의한다.

정답:

- ② 세 문자열이 모두 포함되어야 탐지된다.

설명:

- **condition: \$a or \$b or \$c**는 세 문자열 중 하나라도 포함되면 탐지됨을 의미합니다.
- "모두 포함되어야 탐지된다"는 설명은 틀렸습니다.
- strings 절에는 탐지할 문자열을 정의하고, condition 절에 따라 탐지 조건이 결정됩니다.

39. 다음 중 RSA 암호화에서 랜덤값을 섞고, 패딩을 사용하여 보안성을 높인 방식으로, **Optimal Asymmetric Encryption Padding(OAEP)**을 사용하는 알고리즘은 무엇인가?

- ① RSA-PKCS#1
- ② RSA-OAEP
- ③ RSA-CRT
- ④ RSA-PSS

정답:

- ② RSA-OAEP

설명:

- **RSA-OAEP**는 RSA 암호화에서 **랜덤값을 섞고, 패딩을 적용**하여 보안성을 높인 최적 비대칭 암호 패딩 방식입니다.
- OAEP(Optimal Asymmetric Encryption Padding)는 평문에 무작위 값을 추가해 암호문 패턴을 예측하기 어렵게 만듭니다.
- PKCS#1은 기본 패딩, PSS는 서명용, CRT는 연산 최적화용입니다.
따라서, 랜덤값과 패딩 설명이 나오면 **RSA-OAEP**가 정답입니다.

40. 다음 중 **OSI 7계층의 응용계층(7계층)**에 해당하는 프로토콜 쌍으로 맞는 것은?

- ① IPSec, SSL
- ② SSL, SET
- ③ SET, OTP
- ④ SNMP, IPSec

정답:

- ② SSL, SET

설명:

- **SSL**(Secure Sockets Layer), **SET**(Secure Electronic Transaction)은 모두 응용계층(7계층) 프로토콜입니다.
- **IPSec**은 네트워크 계층(3계층), **OTP**는 인증 방식, **SNMP**는 관리 계층(주로 응용계층이지만, 쌍으로는 잘 나오지 않음)입니다.
- 보기에서 응용계층 프로토콜 두 개가 쌍으로 나온 것을 고르면 됩니다.
따라서 **SSL, SET**이 정답입니다.

41. 다음 중 컴퓨터 바이러스의 발전 순서를 올바르게 나열한 것은?

- ① 원시 → 암호 → 갑옷 → 매크로
- ② 원시 → 갑옷 → 암호 → 매크로
- ③ 매크로 → 원시 → 암호 → 갑옷
- ④ 암호 → 원시 → 매크로 → 갑옷

정답:

- ① 원시 → 암호 → 갑옷 → 매크로

설명:

- **원시 바이러스(Primitive Virus)**: 가장 초기에 등장한 단순한 형태
- **암호 바이러스(Encrypted Virus)**: 탐지를 피하기 위해 암호화 기법 사용
- **갑옷 바이러스(Armored Virus)**: 분석을 어렵게 하는 다양한 방어 기법 적용
- **매크로 바이러스(Macro Virus)**: 매크로 언어를 이용해 문서 파일 등에 감염

이 순서가 바이러스 발전의 대표적인 흐름입니다.

42. SNMP(Simple Network Management Protocol)에서 커뮤니티 스트링(community string)을 보안적으로 안전하게 설정하는 방법으로 옳은 것은?

- ① 커뮤니티 스트링을 기본값(public, private)으로 사용한다.
- ② 커뮤니티 스트링을 복잡하고 추측하기 어려운 값으로 변경한다.
- ③ 커뮤니티 스트링을 모든 네트워크 장비에 동일하게 설정한다.
- ④ 커뮤니티 스트링을 비워둔다.

정답:

- ② 커뮤니티 스트링을 복잡하고 추측하기 어려운 값으로 변경한다.

설명:

SNMP 커뮤니티 스트링은 장비 관리 접근 권한을 제어하는 중요한 값이므로,

- 기본값(public, private) 대신
- **복잡하고 예측 불가능한 값**으로 변경
하는 것이 보안적으로 안전한 설정 방법입니다.
또한, 필요 시 SNMP 접근 제어 리스트(ACL)도 함께 설정하는 것이 좋습니다.

43. 다음 중 나머지와 공격 종류가 다른 것은 무엇인가?

- ① 랜더어택(Land Attack)
- ② 핑 오브 데스(Ping of Death)
- ③ Stacheldraht
- ④ 스텍스넷(Stuxnet)

정답:

- ④ 스텍스넷(Stuxnet)

설명:

- 랜더어택과 핑 오브 데스는 모두 DoS(서비스 거부) 공격의 일종입니다.
- **Stacheldraht**는 DDoS(분산 서비스 거부) 공격 도구입니다.
- ****스텍스넷(Stuxnet)****은 산업 제어 시스템을 노린 악성코드(웜, APT 공격)로, 나머지와 달리 특정 시스템 파괴를 목적으로 하는 고도화된 악성코드입니다.
따라서 성격이 다른 것은 스텍스넷입니다.

44. 다음 중 CISCO에서 개발한 VPN 프로토콜은 무엇인가?

- ① PPTP
- ② L2TP
- ③ L2F
- ④ IPSec

정답:

- ③ L2F

설명:

- **L2F**(Layer 2 Forwarding)는 CISCO에서 개발한 VPN 프로토콜입니다.
- PPTP는 마이크로소프트, L2TP는 IETF와 CISCO 공동, IPSec은 표준 프로토콜입니다.
따라서 CISCO 단독 개발 VPN 프로토콜은 **L2F**입니다.

45. vsftpd로 구동되는 ftp서버에서 ftp를 사용할 수 없는 사용자가 ftp를 사용하게 하려면 어디를 수정해야 하는가?

- ① /etc/ftpusers
- ② /etc/vsftpd.conf
- ③ /etc/pam.d/ftp
- ④ /etc/vsftpd.ftpusers

정답:

- ① /etc/ftpusers

설명:

- `/etc/ftpusers` 파일은 FTP 접속을 **차단할 사용자 목록**을 관리합니다.
- 이 파일에서 해당 사용자를 **제거**하면, 그 사용자는 FTP 접속이 가능해집니다.
- vsftpd 환경에서도 `/etc/ftpusers`가 기본적으로 사용됩니다.
- vsftpd.conf에서 사용자 접근 정책을 추가로 설정할 수도 있지만, 가장 기본적인 차단/허용은 `/etc/ftpusers`에서 관리합니다.

46. 다음 중 ngrep 툴의 옵션에 대한 설명으로 옳지 않은 것은?

- ① `http: http` 필터링
- ② `-w` : 저장옵션
- ③ `dst hostip`
- ④ `-t` : 추적모드

정답:

② `-w` : 저장옵션

설명:

- `http:`는 http 패킷 필터링에 사용
- `dst hostip`는 목적지 호스트 지정
- `-t`는 타임스탬프(추적) 옵션
- `-w`는 저장옵션이 아니라, 문자열 단위(whole word) 매칭 옵션입니다.
따라서 ②번이 틀린 설명입니다.

47. 다음 중 프로세스 할로잉(Process Hollowing) 기법의 절차로 옳은 것은?

- ① 정상 프로세스를 생성하여 `suspend`(일시정지) 상태로 만든다.
- ② 코드 영역에 악성코드용 메모리를 할당한다.
- ③ 악성코드를 코드 영역에 쓴다.
- ④ EIP(명령 포인터)를 악성코드 시작 위치로 변경한다.
- ⑤ 프로세스를 `resume`(재개)하여 악성코드를 실행한다.

정답:

정상 프로세스 `suspend` → 코드 영역에 메모리 할당 → 코드 쓰기 → EIP 변경 → 프로세스 재개

설명:

Process Hollowing은

1. 정상 프로세스를 **suspend** 상태로 생성
2. 코드 영역에 **메모리 할당**
3. **악성코드**를 코드 영역에 쓰기
4. **EIP(명령 포인터)** 변경
5. 프로세스 **resume(재개)**
의 순서로 진행되는 악성코드 은닉 기법입니다.

이 기법은 정상 프로세스처럼 보이지만, 실제로는 악성코드가 실행되도록 합니다.

48. 다음 중 DNS 프로토콜/패킷 분석 시 필요 없는 명령어(도구)는 무엇인가?

- ① dig
- ② nslookup
- ③ host
- ④ ifconfig

정답:

④ ifconfig

설명:

dig, nslookup, host는 모두 DNS 질의 및 응답(프로토콜/패킷) 분석에 사용하는 명령어입니다. ifconfig는 네트워크 인터페이스 설정 및 확인 명령어로, DNS 패킷 분석과는 직접적인 관련이 없습니다. 따라서, 필요 없는 것은 ifconfig입니다.

49. 다음 중 Bill Pugh와 David Hovemeyer가 만든 오픈소스 정적 코드 분석기로, Java 프로그램의 버그를 감시하고 잠재적 오류를 식별하는 도구는 무엇인가?

- ① PMD(Programming Mistake Detector) ② FindBugs ③ SonarQube ④ Jenkins

정답:

② FindBugs

설명:

FindBugs는 Bill Pugh와 David Hovemeyer가 개발한 오픈소스 정적 코드 분석 도구로, Java 프로그램의 버그와 잠재적 오류를 자동으로 탐지합니다. SonarQube, Checkstyle, PMD도 코드 품질 도구이지만, FindBugs가 해당 설명에 맞는 정답입니다.

50. 기타 문제

다음 설명에 맞는 Slow dos 관련된 공격방식을 고르시오(header,post,read,hashdos >> readdos가 정답이었던 것 같아요! mac(메시지) 암호화?하는 함수 듀얼홈드...

- 스크린된 서버넷
 - DMZ 설명나옴 Window register 관련 틀린거 찾기(HKLM,HKCC,HKCU, 등.. 4지선답 찾기)- 공격자가 TCP통신 중 1000개의 () 서버에 전달(SYN,RST,ACK,FIN 4지선 답찾기)